

Exchange Permission Audit Workbook

A normalized, evidence-driven working document for Exchange Online permission auditing

How to use this workbook

Record the audit scope, collection coverage, evidence lineage, review decisions, and post-change validation.
Keep raw source evidence separate from normalized analysis records.

1. Audit scope and ownership

Audit / project name

Evidence date

Tenant / environment

Review period

Audit owner

Control owner

Security reviewer

Change / ticket reference

Permission domains in scope

- | | |
|---|---|
| ☐ Full Access | ☐ Send As |
| ☐ Send on Behalf | ☐ Folder / Calendar |
| ☐ Public folders | ☐ Distribution-group ownership |
| ☐ Exchange RBAC | ☐ Application / service principal access |
| ☐ Identity enrichment | ☐ Effective-access analysis |
| ☐ Purview audit / usage evidence | ☐ Privileged mailbox review |

Scope notes

Collection Coverage

Confirm that each relevant permission control plane has an evidence path.

2. Collection coverage

- ☐ Mailbox permissions collected, including inheritance and Deny where exposed.
- ☐ Send As collected independently from Full Access.
- ☐ Send on Behalf collected independently from Full Access.
- ☐ Folder and calendar permissions sampled or enumerated as required.
- ☐ Public-folder permissions collected with Default / Anonymous entries retained.
- ☐ Distribution-group ownership collected and inactive owners assessed.
- ☐ Role-group membership and effective RBAC assignments reviewed.
- ☐ Application registrations, service principals, consent, and mailbox scoping reviewed.
- ☐ Identity state enriched for disabled, guest, hidden, inactive, or unresolved trustees.
- ☐ Purview audit or other usage/change evidence correlated where required.

3. Collector run manifest

Collection run ID

Collector version

Script / module versions

Start / end UTC

Raw evidence location

Evidence hash / manifest

Expected target count

Collected target count

Run health

- | | | |
|--|--|--|
| ☐ No known errors | ☐ Errors captured | ☐ Throttling observed |
| ☐ Partial run | ☐ Coverage reconciled | ☐ Requires rerun |

Collector notes / exceptions

Normalization and Identity Quality

Preserve raw evidence while creating atomic, traceable entitlement records.

4. Normalization quality gates

- ☐ Every normalized row has Target, PermissionType, Trustee, Source, and EvidenceDate.
- ☐ Raw trustee values are retained alongside resolved identities.
- ☐ Stable identifiers are preferred over display names and SMTP addresses.
- ☐ Inherited values are preserved; unknown inheritance is not silently converted to false.
- ☐ Deny information is preserved where the source supports it.
- ☐ Source-specific permission arrays and attributes remain traceable.
- ☐ Group-expansion lineage is retained separately from the configured group grant.
- ☐ Configured entitlement and effective-access views remain distinct.
- ☐ Rows failing critical data-quality checks are quarantined rather than dropped.

5. Identity resolution

Resolution outcomes

- | | |
|--|--|
| ☐ Resolved by immutable ID / GUID | ☐ Resolved by SID |
| ☐ Resolved by directory object ID | ☐ Resolved by DN / address |
| ☐ Resolved by UPN / alias | ☐ Display-name fallback |
| ☐ Unresolved - investigation required | ☐ Deleted / historical identity |

Identity findings / unresolved trustees

Identity enrichment notes

Entitlement and Effective Access Review

Record configured grants first, then document derived effective access and risk.

6. Permission record sample

finance@contoso.com	FullAccess	Alex Wilber	MailboxPermission	Approved
finance@contoso.com	SendAs	Finance Operators	RecipientPermission	PendingOwner
finance@contoso.com:Ca	Editor	Megan Bowen	MailboxFolderPermissio	Approved
\\Corporate\Policies	PublishingEditor	Default	PublicFolderClientPerm	Remediate
Organization Managemen	RoleGroupMember	Legacy Admin	ExchangeRBAC	Remediate

Model rule

The canonical model is an analysis layer. Retain the original source output so every normalized row can be traced back to evidence.

7. Effective-access analysis

Configured grant / source

Derived effective population

Group / role lineage

Scope / resource boundary

Effective-access checks

☐ Direct grant reviewed

☐ Inheritance origin reviewed

☐ Application scope tested

☐ Group-mediated access reviewed

☐ Deny semantics retained

☐ Computation date / ruleset recorded

Effective-access findings

Risk and Review Register

Use explicit, explainable findings and route them to accountable owners.

8. Risk signals

- | | |
|---|--|
| ☐ Privileged or sensitive target | ☐ Broad group or large effective population |
| ☐ High-impact permission | ☐ Application / service principal access |
| ☐ Unresolved trustee | ☐ Disabled / guest / inactive identity |
| ☐ Stale or missing review evidence | ☐ Scope broader than intended |
| ☐ Unexpected inheritance or Deny interaction | ☐ No named owner or exception expiry |

Risk score / band

Policy / control reference

Finding summary

9. Review decision

Current review status

- | | |
|-------------------------------------|--|
| ☐ Unreviewed | ☐ PendingOwner |
| ☐ Approved | ☐ ApprovedException |
| ☐ Remediate | ☐ RemediationInProgress |
| ☐ Removed | ☐ Rejected |
| ☐ Unresolved | ☐ Expired |

Reviewer

Decision date

Control owner

Next review date

Ticket / exception reference

Exception expiry

Remediation and Attestation

Close the loop with authorized change, post-change collection, validation, and retained evidence.

10. Remediation record

Remediation action

Change reference

Before-state evidence

Post-change evidence

Executed by / automation

Execution timestamp UTC

Post-change validation

- ☐ Permission re-collected
- ☐ Target scope validated
- ☐ Application authorization re-tested

- ☐ Before/after comparison completed
- ☐ Unexpected access paths checked
- ☐ Closure evidence retained

Remediation notes

11. Final attestation

Final disposition

- ☐ Accepted - evidence complete
- ☐ Remediation complete
- ☐ Insufficient evidence
- ☐ Accepted with exception
- ☐ Re-review required

Attestor

Attestation date

Attestation notes / retained evidence package

Evidence principle

Separate inventory, change, and usage evidence. Retain raw evidence so later review can reproduce the finding.